CSIRT Structure and RACI Matrix

Version: 1.0

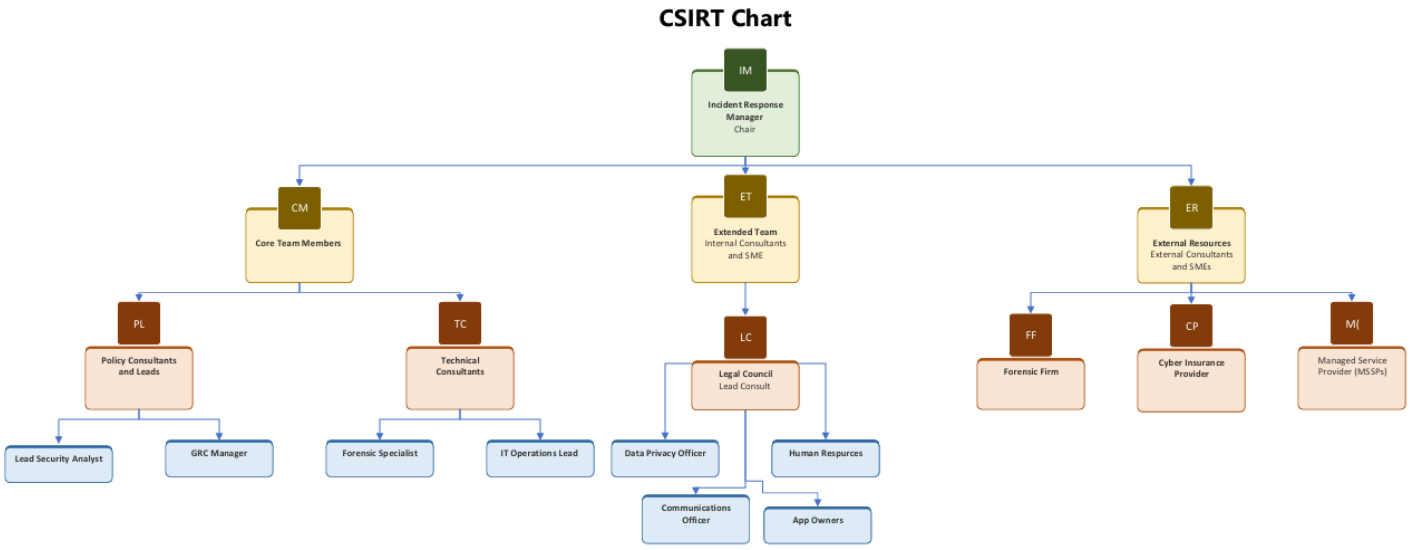
Effective Date: 09. December 2025

Owner: Governance, Risk and Compliance(GRC) Manager

1. CSIRT Organizational Chart

The diagram below is a representation of the CRIST Team chaired by the Incident Response manager and inclusive of the Core Team, representing the Policy and Response Leads and the Technical experts, the extended Team, representing internal consultants and subject matter experts and External Team, representing the consultants.

CIRT Chart



2. Role Definitions

Role	Responsibilities
Incident Response Manager	- The Chair: Leads and coordinates all incident response activities.- Makes critical decisions during an incident.- Provides regular status updates to executive leadership.
Lead Security Analyst	- Performs initial triage and validation of suspected incidents.- Leads the technical investigation.- Analyzes logs, network traffic, and system images.
Forensics Specialist	- Collects and preserves evidence in a forensically sound manner.- Performs deep technical analysis of compromised systems.- Recovers deleted or encrypted data.
IT Operations Lead	- Provides access to affected systems.- Implements containment and eradication actions (e.g., network changes, system rebuilds).- Restores data from backups.
Communications Coordinator	- Manages all internal and external communications during an incident.- Drafts and distributes notifications to stakeholders.- Monitors media and social media for related activity.
Legal Liaison	- Provides guidance on legal and regulatory obligations.- Reviews all external communications.- Manages any interactions with law enforcement.

3. RACI Matrix

RACI Key:

- **R** = Responsible (Does the work)
- **A** = Accountable (Owns the work)
- **C** = Consulted (Provides input)
- **I** = Informed (Kept up-to-date)

Activity	Incident Response Manager	Lead Security Analyst	Forensics Specialist	IT Operations Lead	Communications Coordinator	Legal Liaison	Executive Leadership
Incident Detection & Reporting	A	R	I	I	I	I	I
Incident Validation & Triage	A	R	C	I	I	I	I

Incident Classification	A	R	C	I	I	I	I
Evidence Collection	A	C	R	C	I	C	I
Containment Decision	A	C	C	C	C	C	C
Containment Execution	A	C	I	R	I	I	I
Eradication	A	C	I	R	I	I	I
Recovery	A	C	I	R	I	I	I
Internal Communication	A	I	I	I	R	C	I
External Communication	A	I	I	I	R	C	C
Regulatory Notification	A	I	I	I	C	R	C
Post-Incident Review	R	C	C	C	C	C	A
Lessons Learned	R	C	C	C	C	C	A
IR Plan Updates	R	C	C	C	C	C	A

4. Escalation Procedures

Escalation Criteria:

- **Critical Incidents:** Escalate to executive leadership and legal counsel immediately.
- **High Incidents:** Escalate to the CISO immediately.
- **Incidents involving PHI/PCI data:** Escalate to the Data Privacy Officer and Legal Counsel immediately.
- **Incidents with potential media attention:** Escalate to the Communications team immediately.

Escalation Path:

1. **Security Analyst** detects a potential incident and escalates to the **Lead Security Analyst**.

2. **Lead Security Analyst** validates the incident and escalates to the **Incident Response Manager**.
3. **Incident Response Manager** assesses the severity and escalates to the **CISO** and other relevant stakeholders as per the criteria above.